

DAYANANDA SAGAR COLLEGE OF ENGINEERING

DEPARTMENT OF ARTIFICIAL INTELLIGENCE & MACHINE LEARNING

THREAT MODELLING OF AN
END-TO-END ENCRYPTED (E2EE) AI
CHATBOT

Academic Micro-Project Comprehensive Handbook & Viva Reference Guide
Course: Data Security and Privacy (22AI73) — Semester VII

Student Name:	Saransh Neema	Course Code:	22AI73
USN:	1DS23AI048	Semester / Dept:	VII Sem B.E. / AI & ML
Faculty Guide:	Dr. Aruna M G	Academic Year:	2026
Evaluation Standard:	DSCE Continuous Internal Evaluation	Testing Status:	43 Unit Tests Passed (100%)

Executive Handbook Overview

This project handbook provides a rigorous, end-to-end reference for evaluating and defending the *Threat Modelling of an End-to-End Encrypted AI Chatbot* micro-project. It includes the complete system architecture, trust boundaries, mathematical risk model ($\$R = L \times I\$$), exhaustive STRIDE threat catalogue (all 24 threats), data flow analyses ($\$F_1\$$ to $\$F_6\$$), automated test suite breakdown (43 unit tests), 5-minute teacher demonstration script, and viva voce question answers.

Total Synthetic Threats	Critical Threats (Score ≥ 16)	High Threats (Score 11-15)	Medium (6-10) / Low (1-5)	Automated Pytest Suite
24 (4 per STRIDE class)	4 Immediate blocker	6 Urgent remediation	11 Med / 3 Low Controlled baseline	43 Passed 0 errors / 0.14s

1. System Architecture & Trust Boundaries

The synthetic chatbot architecture comprises **9 Core Components** separated across **4 Trust Boundaries**. Communication between the edge user client and the server queue is protected via End-to-End Encryption (AEAD AES-256-GCM / Double Ratchet). However, because AI neural networks require numeric token embeddings to compute attention matrices, encryption must terminate inside the server's confidential compute cluster, giving rise to the **Plaintext Paradox of AI Inference**.

Component Name	Primary Function	Data Handled	Applicable STRIDE Threats
1. User / Chat Client	Mobile/web edge client UI, local keystore management	User input plaintext, session tokens, ephemeral keys	THR-001 (Spoofing), THR-015 (Info Disclosure)
2. Identity & Auth Service	Credential validation, MFA, and JWT token issuance	Passwords, MFA challenges, signed identity tokens	THR-004 (Spoofing), THR-020 (DoS)
3. Encryption & Key Mgmt	Pre-key distribution, Diffie-Hellman handshake negotiation	Ephemeral DH public keys, signed pre-keys	THR-006 (Tampering)
4. Secure Gateway	Edge ingress proxy, transport TLS termination, rate-limiting	Outer HTTPS/WSS packets, client IP addresses	THR-003 (Spoofing), THR-017 (DoS)
5. Message Relay Server	Asynchronous routing and buffering of encrypted messages	Opaque ciphertext blobs, routing headers	THR-005 (Tampering), THR-013, THR-019 (DoS)
6. AI Processing Service	Confidential enclave for model inference and response gen	Decrypted plaintext prompt, LLM attention KV cache	THR-002, THR-007 (Tampering), THR-014, THR-018
7. API Layer	Internal microservices router enforcing RBAC/ABAC policies	Service RPC requests, internal bearer tokens	THR-021 (IDOR), THR-022 (Privilege Escalation)
8. Logging & Audit Service	Centralized immutable security event and access logging	Timestamped audit records, system error traces	THR-010, THR-012 (Repudiation), THR-016
9. Admin Interface	Operations console for security configurations and telemetry	Admin credentials, routing policies, key lifecycles	THR-008 (Tampering), THR-011, THR-024

Trust Boundary Definitions:

- **TB-01 (Untrusted Client Boundary):** Separates end-user mobile/web hardware from the public transit network.
- **TB-02 (Perimeter DMZ Boundary):** Separates the untrusted internet from the cloud ingress gateway and relay.
- **TB-03 (Confidential Compute Boundary):** Separates message queues from the isolated hardware-enforced AI execution enclave (AMD SEV-SNP).
- **TB-04 (Management Plane Boundary):** Separates operational application logic from the privileged administrative and audit console.

2. Mathematical Risk Model & Scoring Tiers

Risk prioritization is governed by a quantitative two-variable scoring formula aligned with NIST SP 800-30:

$$\text{Risk Score} = \text{Likelihood} \times \text{Impact} \quad [R = L \times I]$$

Where **Likelihood (L)** $\in$ [1, 5] and **Impact (I)** $\in$ [1, 5]. The output risk score is bounded within [1, 25].

Risk Score Range	Classification Tier	Severity Action & SLA	Threat Count in Model
1 – 5	Low Risk	Accept risk or address during routine maintenance cycles.	3 threats (12.5%)
6 – 10	Medium Risk	Schedule mitigation in next development sprint; monitor telemetry.	11 threats (45.8%)
11 – 15	High Risk	High priority remediation required prior to release candidate sign-off.	6 threats (25.0%)
16 – 25	Critical Risk	Immediate blocking vulnerability; halts deployment until mitigated.	4 threats (16.7%)

5 × 5 Risk Matrix Cell Layout & Viva Explanation Guide

During examination, evaluators frequently test risk comprehension by picking arbitrary coordinate pairs on the 5×5 matrix:

- **L=4, I=4 → Score: 16 (Critical):** Upper quadrant risk. Examples: *THR-007 (Prompt Injection)*, *THR-014 (Attention Cache Leak)*.
- **L=2, I=5 → Score: 10 (Medium):** High impact catastrophe, but rare likelihood keeps score at 10 (Medium tier). Example: *THR-002 (Rogue Worker Node)*.
- **L=3, I=4 → Score: 12 (High):** Frequent credential attacks with significant impact. Example: *THR-001 (User Impersonation)*.
- **L=1, I=1 → Score: 1 (Low):** Minimum possible mathematical boundary value.

Residual Risk Calculation Formula (Post-Mitigation Posture):

Implemented in `core/mitigation_engine.py`, residual risk estimates post-control vulnerability:

- **Status = 'Mitigated':** Likelihood reduced by 2 (min 1), Impact reduced by 1 (min 1).
- **Status = 'In Progress':** Likelihood reduced by 1 (min 1), Impact unchanged.
- **System Baseline:** Initial average risk score is **10.38**. Post-mitigation residual score is **5.92**, demonstrating a **43.0% quantitative risk reduction**.

3. Complete Synthetic STRIDE Threat Catalogue (24 Threats)

The model contains exactly 24 synthetic threats across 9 components, with an exact balanced distribution of 4 threats per STRIDE category.

ID / Name	STRIDE / Comp	L × I = Score	Security Control & Mitigation
THR-001 User Identity Impersonation	Spoofing User / Chat Client	L=3, I=4 12 (High)	Hardware-backed Keystore & mTLS Attestation Enforce hardware-backed keystore (Android Keystore / iOS Secure Enclave) for client public...
THR-002 Rogue AI Inference Node Registration	Spoofing AI Processing Service	L=2, I=5 10 (Medium)	SPIFFE/SPIRE Service Mesh Node Attestation Service mesh mutual authentication (SPIFFE/mTLS) with cryptographically attested worker id...
THR-003 Gateway DNS Spoofing & Fake Endpoint	Spoofing Secure Gateway	L=2, I=4 8 (Medium)	Certificate Pinning & HSTS Preloading Certificate pinning on client applications, strict HTTP Strict Transport Security (HSTS) w...
THR-004 Session & Bearer Token Impersonation	Spoofing Identity & Authentication	L=3, I=4 12 (High)	Proof-of-Possession (DPoP) Token Binding Cryptographically bound Proof-of-Possession (DPoP / mTLS token binding) tokens with short ...
THR-005 Envelope Routing Header Manipulation	Tampering API Layer	L=2, I=2 4 (Low)	Authenticated Encryption with Associated Data (AEAD) Authenticated Encryption with Associated Data (AEAD, e.g., AES-256-GCM / ChaCha20-Poly1305...
THR-006 In-Flight Ephemeral Key Tampering	Tampering Encryption / Key Management	L=2, I=5 10 (Medium)	Double Ratchet with Signed Prekeys (X3DH) Cryptographic digital signatures on all ephemeral key exchanges using long-term pre-authen...
THR-007 Indirect Prompt Injection & Context Manipulation	Tampering AI Processing Service	L=4, I=4 16 (Critical)	Dual-LLM Guardrail Filters & Boundary Token Delimiters Strict multi-tier prompt sandboxing, dual LLM guardrails (input/output sanitizers), struct...
THR-008 Security Configuration Manipulation	Tampering Administration Interface	L=2, I=4 8 (Medium)	Cryptographically Signed Policy Manifests Cryptographically signed configuration manifests with immutable schema validation and vers...
THR-009 User Denies Sending Malicious Prompt	Repudiation User / Chat Client	L=2, I=2 4 (Low)	Client-Side Digital Signatures & Sequence Counters Cryptographic digital signatures on client message payloads with monotonic sequence counte...
THR-010 Audit Trail Erasure by Privileged Operator	Repudiation Logging / Audit Service	L=2, I=4 8 (Medium)	WORM Storage & Merkle Hash Chains Append-only Write-Once-Read-Many (WORM) storage, cryptographically chained Merkle tree aud...

THR-011 Unsigned Administrative Policy Override	Repudiation Administration Interface	L=2, I=4 8 (Medium)	FIDO2 Hardware-Signed Dual-Custody Manifests Dual-control (four-eyes principle) change verification and hardware security token (FIDO2/...
THR-012 Gateway Routing Log Ingestion Failure / Drop	Repudiation Logging / Audit Service	L=2, I=2 4 (Low)	Guaranteed Backpressure Logging Pipeline Guaranteed delivery message queues with backpressure flow control and persistent local spi...
THR-013 Plaintext Message Exposure in Relay Queue	Information Disclosure Message Relay Server	L=3, I=4 12 (High)	Zero-Knowledge Routing & Enclave Payload Isolation Strict Zero-Knowledge message routing: relay is cryptographically incapable of accessing k...
THR-014 Cross-Session Attention KV Cache Leakage	Information Disclosure AI Processing Service	L=4, I=4 16 (Critical)	AMD SEV-SNP Enclaves & Per-Turn KV Attention Flush Strict process/GPU memory isolation between tenant inference jobs, explicit cache flushing...
THR-015 Client-Side Ephemeral Key Memory Extraction	Information Disclosure Encryption / Key Management	L=3, I=5 15 (High)	Immediate Memory Zeroization (mlock) & Secure Enclave Zeroization of cryptographic keys immediately after use ('mlock' memory buffers), anti-deb...
THR-016 Sensitive Conversational Data in Error Logs	Information Disclosure Logging / Audit Service	L=2, I=5 10 (Medium)	Zero-Plaintext Logging & Automated PII/Secret Redaction Automated log scrubbing regex filters, strict zero-plaintext logging policy, and different...
THR-017 Asymmetric TLS Handshake Exhaustion Attack	Denial of Service Secure Gateway	L=4, I=4 16 (Critical)	Edge SYN-Cookies & eBPF XDP Rate Limiting Edge rate-limiting, SYN cookies, stateless handshake filtering (e.g. Cloudflare / eBPF XDP...
THR-018 AI Inference Resource Exhaustion via Recursive Prompts	Denial of Service AI Processing Service	L=4, I=4 16 (Critical)	Token Generation Quotas & Inference Timeouts Per-user token throttling, hard timeout quotas on inference steps, context window capping,...
THR-019 Relay Buffer Overfill with Bogus Ciphertext Blobs	Denial of Service Message Relay Server	L=3, I=3 9 (Medium)	Leaky-Bucket Per-Client Throttling & Payload Size Thresholds Strict message payload size boundaries (e.g., max 64KB per prompt), leaky-bucket rate limi...
THR-020 Authentication Endpoint Brute-Force Abuse	Denial of Service Identity & Authentication	L=3, I=3 9 (Medium)	Adaptive Rate Limiting & Proof-of-Work Puzzles Adaptive IP reputation scoring, distributed rate limiting per subnet, and progressive proo...
THR-021 Insecure Direct Object Reference (IDOR) on Admin API	Elevation of Privilege Administration Interface	L=2, I=5 10 (Medium)	Fine-Grained Attribute-Based Access Control (ABAC) Attribute-Based Access Control (ABAC), fine-grained role authorization enforcement at the ...
THR-022 JWT Algorithm Confusion & Role Escalation	Elevation of Privilege Identity & Authentication	L=3, I=4 12 (High)	Cryptographic Algorithm Whitelisting (RS256/EdDSA Only) Strict cryptographic algorithm whitelisting in JWT validator, rejecting 'none' and mismatc...

THR-023 AI Inference Worker Container Breakout	Elevation of Privilege API Layer	L=3, I=4 12 (High)	gVisor MicroVM Sandboxing & Read-Only Root Filesystems Rootless containers, gVisor / Firecracker microVM sandboxing, disabling seccomp dangerous ...
THR-024 Excessive Service Permissions on Relay Worker	Elevation of Privilege Message Relay Server	L=2, I=4 8 (Medium)	Least-Privilege IAM Scoping & IMDSv2 Hardening Principle of least privilege (PoLP) IAM scoping, short-lived STS tokens, and blocking IMDS...

4. Automated Testing & Verification Suite

The project includes **43 automated unit tests** in tests/test_risk_engine.py executed via pytest -v. All 43 test cases pass in **0.14 seconds** with 0 errors and 0 warnings, verifying 100% mathematical and schema integrity.

Test Class Name	Tests	Key Validations & Security Properties Verified
TestRiskEngine	27 tests	Formula accuracy ($\$3 \times 4 = 12\$$), min/max boundaries ($\$1 \times 1 = 1\$$, $\$5 \times 5 = 25\$$), all 4 tier classifications, and ValueError handling for out-of-bounds inputs ($\$L$, $l \notin [1, 5]\$$).
TestThreatEngine	9 tests	Dataset loading (24 threats), exact STRIDE balance (4 in each of S, T, R, I, D, E), multi-criteria filters (category, component, tier), and free-text search functionality.
TestMitigationEngine	4 tests	9 mitigation category completeness, threat-to-control grouping, traceability matrix generation, and residual risk reduction calculations.
TestAssetAndDataFlowEngines	3 tests	9 protected assets with CIA ratings, data flows $\$F_1\$$ to $\$F_6\$$ with trust boundary traversals, and 9 security vs. privacy analytical topics.

Exact Verification Execution Commands (Windows PowerShell):

```
# 1. Activate virtual environment
.\.venv\Scripts\Activate.ps1

# 2. Run test suite with verbose output
pytest -v

# Output confirmation:
===== 43 passed in 0.14s =====
```

Implemented Software Prototype vs. Conceptual Security Controls

To ensure academic honesty during viva voce examination, the table below clearly demarcates features implemented in working Python code versus conceptual defenses modeled as architectural requirements:

Security / System Feature	Implemented in Python Code?	How to Explain to Viva Examiner
STRIDE Threat Engine & Catalogue	YES (Implemented)	Fully implemented in core/threat_engine.py and data/threats.json.
Mathematical Risk Calculator	YES (Implemented)	Fully implemented in core/risk_engine.py with 100% test coverage.
Mitigation Traceability Matrix	YES (Implemented)	Fully implemented in core/mitigation_engine.py.
Streamlit Interactive UI & Heatmap	YES (Implemented)	Interactive dashboard implemented in app.py with Plotly graphics.
Automated Testing Suite (43 tests)	YES (Implemented)	Complete unit test suite running via pytest in tests/test_risk_engine.py.
Signal Double Ratchet E2EE	NO (Conceptual)	Modeled as an architectural mitigation requirement; not a live production crypto service.
Hardware Enclaves (AMD SEV-SNP)	NO (Conceptual)	Proposed confidential compute defense required to mitigate plaintext memory leaks.
RAM Zeroization (mlock)	NO (Conceptual)	Proposed endpoint defense against client-side memory dump extraction.

WORM Merkle Audit Logging	NO (Conceptual)	Architectural non-repudiation control to detect log erasure or tampering.
---------------------------	-----------------	---

5. Viva Voce Reference & Demonstration Cheat Sheet

5-Minute Live Demonstration Flow:

- Minute 1 (Dashboard):** Present your name, USN, course (22AI73), and highlight the 24 threats across 9 components.
- Minute 2 (Architecture):** Open Architecture page, explain the 9 components and 4 Trust Boundaries, noting that decryption terminates at the AI Enclave.
- Minute 3 (STRIDE Model):** Filter by 'Critical' risk tier; explain *THR-007 (Indirect Prompt Injection)* and why E2EE cannot stop semantic prompt jailbreaks.
- Minute 4 (Risk Heatmap & Controls):** Show the 5×5 Plotly heatmap; transition to Mitigation Controls and explain the 43% average risk reduction.
- Minute 5 (Testing & Conclusion):** Open Testing page, click 'Run All Automated Tests', show all 43 tests passing in 0.14s, and conclude.

Frequently Asked Viva Questions & Standard Responses:

Examiner Question	Optimal Concise Answer
Why is E2EE different for an AI chatbot than WhatsApp?	In WhatsApp, both endpoints are humans. In an AI chatbot, the recipient is a server-side AI model that must decrypt prompts in server RAM to compute token embeddings and attention weights.
What is STRIDE and what security properties does it map to?	STRIDE maps to foundational security properties: Spoofing (Authenticity), Tampering (Integrity), Repudiation (Accountability), Information Disclosure (Confidentiality), Denial of Service (Availability), and Elevation of Privilege (Authorization).
Why is a risk score of 16 classified as Critical?	Any threat with high likelihood (4) and high impact (4) causes immediate catastrophic damage ($4 \times 4 = 16$). In standard 4-tier risk governance, scores 16–25 represent deployment-blocking risks.
Why did you use synthetic data?	To comply with privacy laws (GDPR, DPDP Act 2023) and ethical security research practices by avoiding the collection or handling of real user credentials.
What UN SDG goal does this align with?	SDG 9: Industry, Innovation, and Infrastructure (specifically Target 9.c & 9.1 for secure, resilient information and communication technology infrastructure).